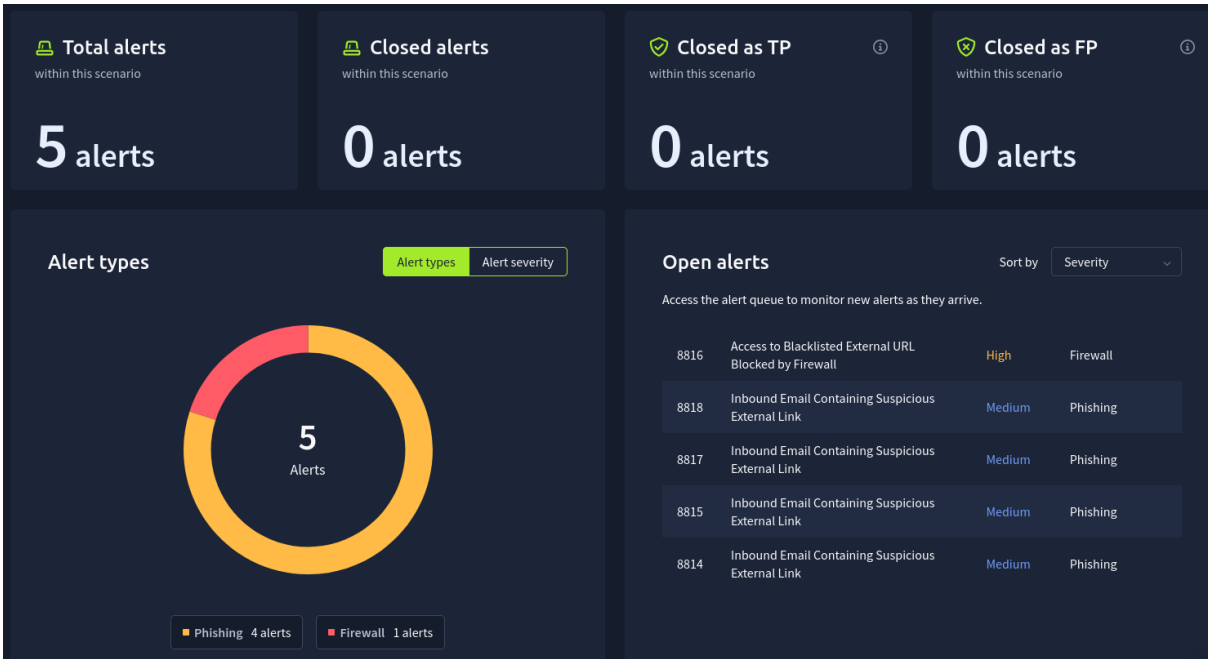
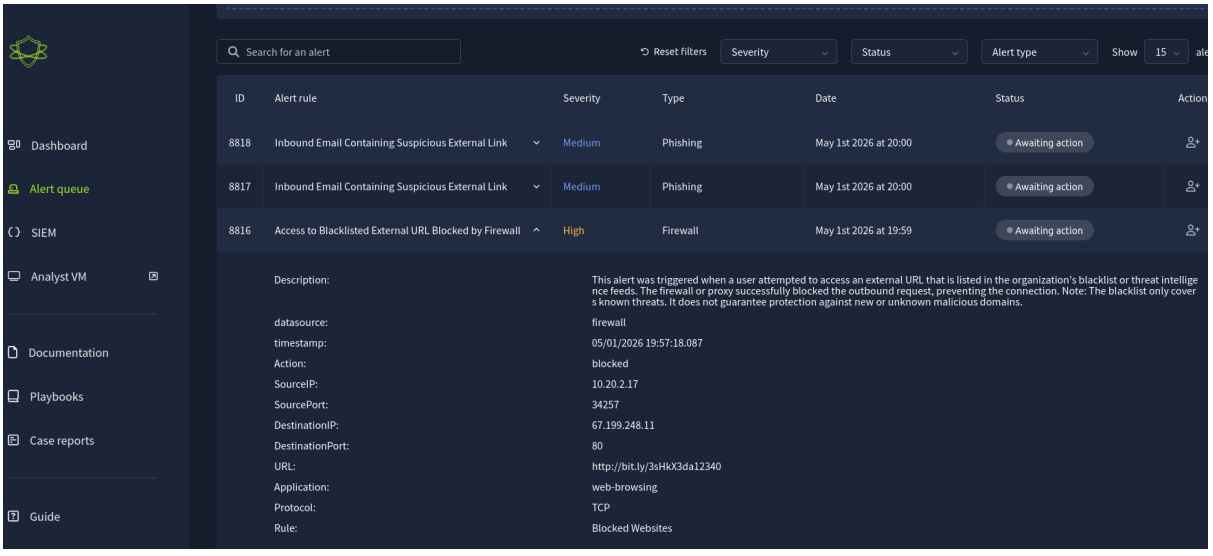
Dia de trabalho de um SOC analyst L1 na prática

Nesse cenário sou um analista SOC L1 reponsável em monitorar e analisar alertas em tempo real no SIEM (Splunk), correlacionar dados e classificar como True Positive (TP) ou False Positive (FP), decidir se escalo ou não, e escrever relatório.



Alerta 1

Na fila de alertas, decidi analisar por severidade (High):
8816 - Access to Blacklisted External URL Blocked by Firewall - High - Firewall



Description:

This alert was triggered when a user attempted to access an external URL that is listed in the organization's blacklist or threat intelligence feeds. The firewall or proxy successfully blocked the outbound request, preventing the connection. Note: The blacklist only covers known threats. It does not guarantee protection against new or unknown malicious domains.

datasource: firewall

timestamp: 05/02/2026 13:00:10.865

Action: blocked

SourceIP: 10.20.2.17

SourcePort: 34257

DestinationIP: 67.199.248.11

DestinationPort: 80

URL: http://bit.ly/3sHkX3da12340

Application: web-browsing

Protocol: TCP

Rule: Blocked Websites

🎯 📌 RESUMO DO ALERTA

- **IP interno:** 10.20.2.17
- **Usuário (pela tabela):** Hannah Harris (RH)
- **Destino:** 67.199.248.11
- **URL:** bit.ly (encurtador)
- **Ação: blocked ✔**
- **Regra:** Blocked Websites
- **Severidade:** High

🧠 🔍 **ANÁLISE REAL**

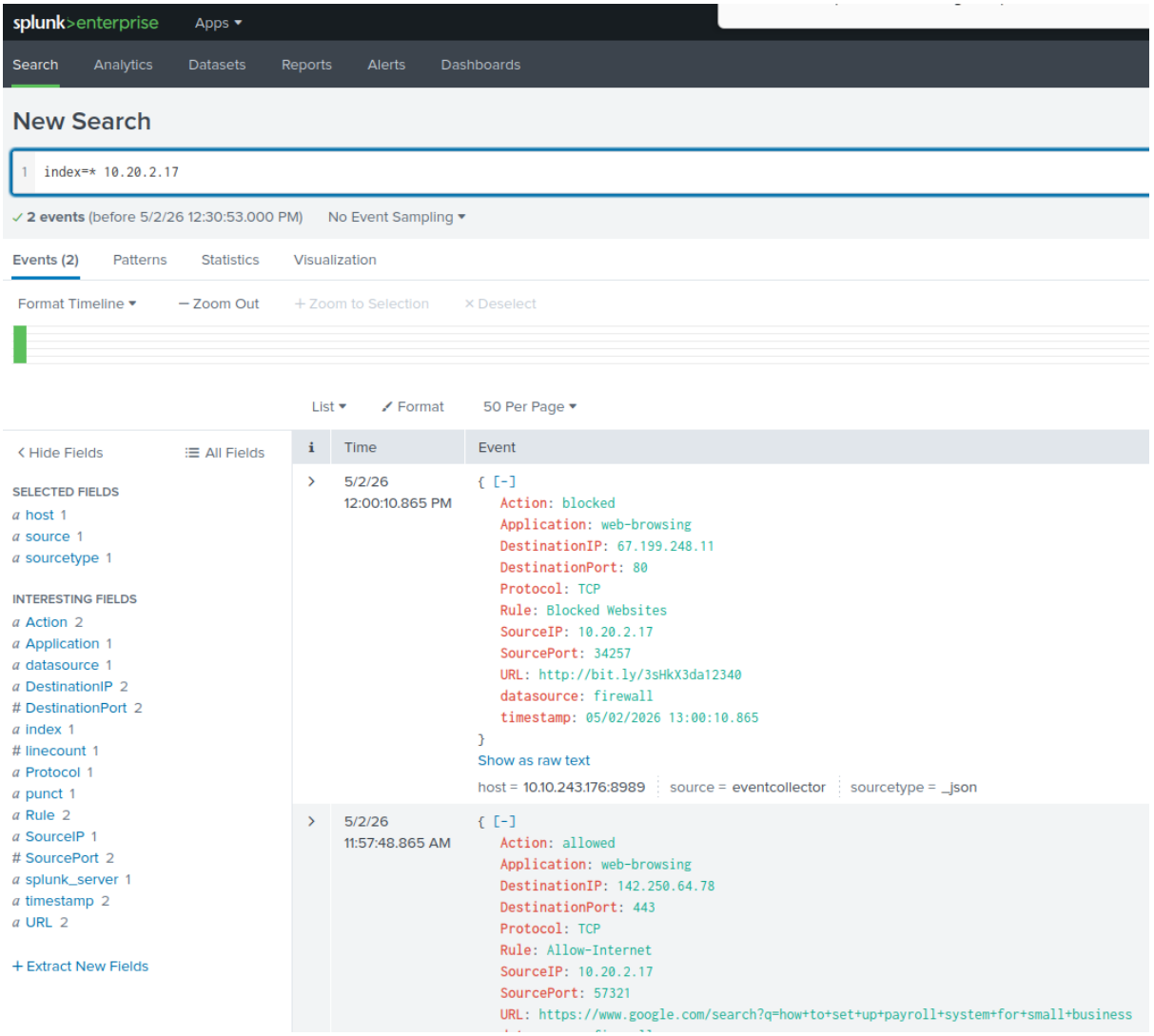
👉 O que aconteceu:

- Usuário tentou acessar um link encurtado (bit.ly)
- Esse tipo de link é MUITO usado em phishing
- O firewall reconheceu como suspeito
- **Bloqueou antes de qualquer conexão acontecer**

O alerta é apenas o ponto de partida. Eu sempre valido no SIEM para obter contexto adicional, como frequência, origem e impacto da atividade. Por isso vamos analisar algumas coisas no SIEM (Splunk):

1- Analisar se houve mais tentativas:

index=* 10.20.2.17



2 - Analisar se alguém conseguiu acessar (allowed)

index=* "67.199.248.11"

i	Time	Event
>	5/2/26 12:00:10.865 PM	{ [-] Action: blocked Application: web-browsing DestinationIP: 67.199.248.11 DestinationPort: 80 Protocol: TCP Rule: Blocked Websites SourceIP: 10.20.2.17 SourcePort: 34257 URL: http://bit.ly/3sHkX3da12340 datasource: firewall timestamp: 05/02/2026 13:00:10.865 } Show as raw text host = 10.10.243.176:8989 | source = eventcollector | sourcetype = _json
>	5/2/26 11:57:48.865 AM	{ [-] Action: allowed Application: web-browsing DestinationIP: 142.250.64.78 DestinationPort: 443 Protocol: TCP Rule: Allow-Internet SourceIP: 10.20.2.17 SourcePort: 57321 URL: https://www.google.com/search?q=how+to+set+up+payroll+system+for+small+business datasource: firewall timestamp: 05/02/2026 12:57:48.865 } Show as raw text host = 10.10.243.176:8989 | source = eventcollector | sourcetype = _json

3. Analisar origem (email phishing?)

index=* "bit.ly"

i	Time	Event
>	5/2/26 12:00:10.865 PM	{ [-] Action: blocked Application: web-browsing DestinationIP: 67.199.248.11 DestinationPort: 80 Protocol: TCP Rule: Blocked Websites SourceIP: 10.20.2.17 SourcePort: 34257 URL: http://bit.ly/3sHkX3da12340 datasource: firewall timestamp: 05/02/2026 13:00:10.865 } Show as raw text host = 10.10.243.176:8989 | source = eventcollector | sourcetype = _json
>	5/2/26 11:58:56.865 AM	{ [-] attachment: None content: Dear Customer,\n\nWe were unable to deliver your package due to an incomplete address.\n\nPlease confirm your shipping information by clicking the link below:\n\nhttp://bit.ly/3sHkX3da12340\n\nIf we don't hear from you within 48 hours, your package will be returned to sender.\n\nThank you,\n\nAmazon Delivery datasource: email direction: inbound recipient: h.harris@thetrydaily.thm sender: urgents@amazon.biz subject: Your Amazon Package Couldn't Be Delivered - Action Required timestamp: 05/02/2026 12:58:56.865 } Show as raw text host = 10.10.243.176:8989 | source = eventcollector | sourcetype = _json

⚖️ 🎯 CLASSIFICAÇÃO CORRETA

❌ NÃO é False Positive

Por quê?

- bit.ly é comum em campanhas maliciosas
- comportamento é potencialmente perigoso

✅ CLASSIFICAÇÃO CERTA:

👉 True Positive

📌 Porque:

houve tentativa de acesso a recurso malicioso

🚨 📊 **ESCALONAMENTO**

👉 **Escalar ou não?**

➡️ Neste caso:

✔ Firewall bloqueou
✔ Nenhuma execução
✔ Nenhuma conexão estabelecida

🎯 **DECISÃO:**

👉 **True Positive — SEM escalonamento**

📝 ✍️ **RELATÓRIO FINAL**

Time of activity:
05/01/2026 19:57:18

List of Affected Entities:

- User: Hannah Harris (h.harris@thetrydaily.thm)
- Source IP: 10.20.2.17
- Host: win-3457
- Destination IP: 67.199.248.11
- URL: http://bit.ly/3sHkX3da12340

Reason for Classifying as True Positive:
This activity is classified as a True Positive because a user from the internal network attempted to access a blacklisted external URL. The URL uses a URL shortening service (bit.ly), which is commonly associated with phishing campaigns and malicious redirections. The destination is listed in threat intelligence feeds, confirming its malicious nature.

Reason for Escalating the Alert:
Escalation is not required in this case. Although the activity involved a malicious URL, the firewall successfully blocked the request, preventing any connection to the external host. No further suspicious activity or signs of compromise were observed on the affected system.

Recommended Remediation Actions:

- Educate the user about phishing risks and suspicious links
- Monitor the user's activity for any repeated attempts
- Ensure endpoint protection is active and updated
- Continue monitoring similar firewall blocks for patterns indicating phishing campaigns

List of Attack Indicators:

- Source IP: 10.20.2.17
- Destination IP: 67.199.248.11
- URL: http://bit.ly/3sHkX3da12340
- Protocol: TCP
- Destination Port: 80
- Application: web-browsing

Alerta 2

🎯 🧠 ANÁLISE RÁPIDA

👉 O que temos:

- Email externo (**inbound**)
- Link para “onboarding”
- Pressão leve (“Action Required”)
- Link clicável
- Nenhum anexo

🔍 🚨 SINAIS DE ALERTA

👉 Pontos suspeitos:

- Domínio **hrconnex.thm** (não sabemos se é confiável)
- Uso de link direto para ação
- Engenharia social (onboarding / acesso)
- Usuária real da empresa (Julia Garcia)

🧠 🥇 PERGUNTA PRINCIPAL (SOC)

👉 **Alguém clicou no link?**

Isso define tudo:

- ❌ Não clicou → baixo risco
- 🔴 Clicou → risco alto

🎯 🧪 NO SIEM

🔥 1. Procurar acesso ao domínio

index=* "hrconnex.thm"

i	Time	Event
>	5/1/26 7:00:26.623 PM	{ [-] attachment: None content: Hi Ms. Garcia,\n\nWelcome to TheTryDaily!\n\nAs part of your onboarding, please complete your final profile setup so we can configure your access.\n\nKindly click the link below:\n\n<a href="https://hrconnex.thm/onboarding/15400654060/j.garcia">Set Up My Profile</a>.\n\nIf you have questions, please reach out to the HR Onboarding Team. datasource: email direction: inbound recipient: j.garcia@thetrydaily.thm sender: onboarding@hrconnex.thm subject: Action Required: Finalize Your Onboarding Profile timestamp: 05/01/2026 20:00:26.623 } Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json
>	5/1/26 6:56:00.623 PM	{ [-] attachment: None content: Hi IT Team,\n\nHope you're doing well! I'm reaching out because one of our new hires, J. Garcia, hasn't received her onboarding email from hrconnex.thm, which is our new third-party HR partner for handling account setup and paperwork.\n\nHe was supposed to receive a link to complete her profile and sign some documents, but it hasn't come through – not in her inbox or spam. We've double-checked the email address on our end, and it's correct.\n\nLet me know if you need any more info from my side.\n\n datasource: email direction: internal recipient: j.carter@thetrydaily.thm sender: h.harris@thetrydaily.thm subject: Unable to Receive Onboarding Email from hrconnex.thm timestamp: 05/01/2026 19:56:00.623 } Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json
>	5/1/26 6:54:27.623 PM	{ [-] attachment: None content: Hi Ms. Garcia,\n\nWelcome to TheTryDaily!\n\nAs part of your onboarding, please complete your final profile setup so we can configure your access.\n\nKindly click the link below:\n\n<a href="https://hrconnex.thm/onboarding/15400654060/j.garcia">Set Up My Profile</a>.\n\nIf you have questions, please reach out to the HR Onboarding Team. datasource: email direction: inbound recipient: j.garcia@thetrydaily.thm sender: onboarding@hrconnex.thm subject: Action Required: Finalize Your Onboarding Profile timestamp: 05/01/2026 19:54:27.623 } Show as raw text host = 10.10.152.173:8989 source = eventcollector sourcetype = _json

🧠 🔍 Descoberta

📧 1. Email interno ANTES do alerta

- Hannah Harris (RH) falou com TI
- Disse que:

> A nova funcionária **Julia Garcia deveria receber email do hrconnex.thm**

👉 Isso valida o domínio!

📧 2. Email recebido pela Julia

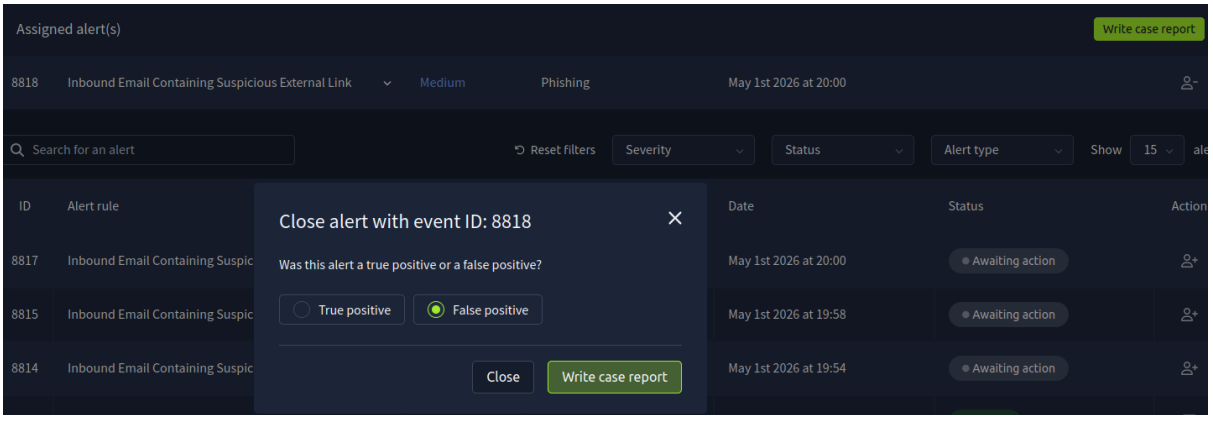
- Mesmo domínio: **hrconnex.thm**
- Mesmo contexto: onboarding
- Conteúdo coerente

NÃO parece ataque

🎯 💥 CONCLUSÃO

👉 Esse NÃO é phishing

✅ False Positive



🧠 💡 POR QUE?

✔ Domínio mencionado previamente por funcionário interno
✔ Contexto legítimo (onboarding de nova funcionária)
✔ Comunicação consistente
✔ Nenhum sinal de spoofing ou fraude

🚨 ⚖️ CLASSIFICAÇÃO FINAL

👉 **False Positive**
👉 **Sem escalonamento**

📝 ✍️ RELATÓRIO FINAL

Time of activity:
05/01/2026 19:54:27 – 20:00:26

List of Affected Entities:

- User: Julia Garcia (j.garcia@thetrydaily.thm)
- Sender: onboarding@hrconnex.thm
- Related User: Hannah Harris (h.harris@thetrydaily.thm)
- Internal Host: win-3452 (10.20.2.8)

Reason for Classifying as False Positive:
This activity is classified as a False Positive. Although the email initially appeared suspicious due to the presence of an external link and social engineering characteristics, further investigation revealed that the domain hrconnex.thm is a legitimate third-party HR service used by the organization.

An internal email from Hannah Harris (HR department) confirmed that Julia Garcia was expected to receive an onboarding email from this domain. The content, timing, and context of the email are consistent with legitimate onboarding procedures. No indicators of malicious intent or compromise were identified.

Reason for Escalating the Alert:
Escalation is not required. The activity was verified as legitimate business communication, and no suspicious or malicious behavior was detected.

Recommended Remediation Actions:

- Review and fine-tune detection rules to reduce similar false positives
- Whitelist the hrconnex.thm domain if appropriate
- Continue monitoring for abnormal use of trusted domains

List of Attack Indicators:

- Sender: onboarding@hrconnex.thm

- Recipient: j.garcia@thetrydaily.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Subject: Action Required: Finalize Your Onboarding Profile

Alerta 3

Na descrição do alerta parece se tratar de um **phishing clássico e perigoso** 👀🔥

🎯 🧠 ANÁLISE RÁPIDA

👉 O que temos:

- Domínio falso: **m1crosoftsupport.co** (com “1” no lugar de “i”)
- Tema urgente: “Unusual Sign-In Activity”
- Engenharia social (medo + urgência)
- Link para login
- IP e localização (Lagos) para dar credibilidade

🚨 🔴 RED FLAGS (muito fortes)

- Typosquatting (m1crosoft ≠ microsoft)
- Domínio externo desconhecido
- Pedido para clicar e logar
- Simulação de alerta de segurança

👉 Isso é **credential harvesting (roubo de senha)**

🧪 CHECAR NO SPLUNK

Charlotte Allen clicou no link?

🔍 Buscar acesso ao domínio

index=* "m1crosoftsupport.co"

```
5/1/26
7:01:07.623 PM
{ [-]
  Action: allowed
  Application: web-browsing
  DestinationIP: 45.148.10.131
  DestinationPort: 443
  Protocol: TCP
  Rule: Allow-Internet
  SourceIP: 10.20.2.25
  SourcePort: 32653
  URL: https://m1crosoftsupport.co/login
  datasource: firewall
  timestamp: 05/01/2026 20:01:07.623
}
Show as raw text
host = 10.10.152.173:8989   source = eventcollector   sourcetype = _json
```

```
5/1/26
6:59:58.623 PM
{ [-]
  attachment: None
  content: Hi C.Allen,\n\nWe detected an unusual sign-in attempt on your Microsoft account.\n\nLocation: Lagos, Nigeria\n\nIP Address: 102.89.222.143\n\nDate: 2025-01-24 06:42\n\nIf this was not
you, please secure your account immediately to avoid unauthorized access.\n\n<a href="https://m1crosoftsupport.co/login">Review Activity</a>\n\nThank you,\n\nMicrosoft Account Security Team
  datasource: email
  direction: inbound
  recipient: c.allen@thetrydaily.thm
  sender: no-reply@m1crosoftsupport.co
  subject: Unusual Sign-In Activity on Your Microsoft Account
  timestamp: 05/01/2026 19:59:58.623
}
Show as raw text
host = 10.10.152.173:8989   source = eventcollector   sourcetype = _json
```

Acabo de confirmar que o link foi acessado e isso virou um **incidente real de segurança** 👀🔥

🚨 🧠 O QUE ACONTECEU (linha do tempo)

📧 19:59:58

- Email phishing recebido (m1crosoftsupport.co)

🌐 20:01:07

- Usuária **Charlotte Allen (10.20.2.25)**
- **ACESSOU o link**
- **Action: allowed** ❌

🎯 💥 CONCLUSÃO

👉 O usuário **clicou no link malicioso**
👉 A conexão foi **permitida pelo firewall**

🚨 🚨 **CLASSIFICAÇÃO**

👉 **True Positive (confirmado)**

🔥 🚨 **ESCALONAMENTO**

👉 **SIM — ESCALATION REQUIRED**

Por quê?

- Possível roubo de credenciais
- Usuário interagiu com phishing
- Acesso ao site malicioso foi permitido

🧠 💡 **Isso é exatamente o que SOC chama de:**

👉 **User Compromise Risk**

🧾 ✍️ RELATÓRIO FINAL

Time of activity:
05/01/2026 19:59:58 – 20:01:07

List of Affected Entities:

- User: Charlotte Allen (c.allen@thetrydaily.thm)
- Source IP: 10.20.2.25
- Host: win-3463
- Destination IP: 45.148.10.131
- Malicious Domain: m1crosoftsupport.co

Reason for Classifying as True Positive:
This activity is classified as a True Positive due to a confirmed phishing attack. The email originated from a typosquatted domain (m1crosoftsupport.co), impersonating Microsoft to deceive the user. The email contained social engineering elements such as urgency and security warnings to prompt user action.

Further investigation confirmed that the recipient accessed the malicious URL (https://m1crosoftsupport.co/login), establishing a successful outbound connection to the external server (45.148.10.131). This indicates that the phishing attempt progressed beyond delivery and user interaction occurred.

Reason for Escalating the Alert:
Escalation is required as the user interacted with the phishing email and accessed the malicious website. This creates a high risk of credential compromise and potential unauthorized access to corporate systems. Immediate response actions are necessary to contain and mitigate the threat.

Recommended Remediation Actions:

- Force password reset for the affected user
- Invalidate active sessions and tokens
- Monitor for suspicious login activity
- Perform endpoint scan on the affected host
- Block the malicious domain and IP at firewall level

- Conduct phishing awareness training for the user

List of Attack Indicators:

- Sender: no-reply@m1crosoftsupport.co
- Recipient: c.allen@thetrydaily.thm
- Source IP: 10.20.2.25
- Destination IP: 45.148.10.131
- URL: https://m1crosoftsupport.co/login
- Protocol: TCP
- Port: 443

🔥 🧠 O QUE FOI FEITO

✔ correlacionei email + firewall
✔ identifiquei clique real
✔ detectei risco de comprometimento
✔ decidi escalar corretamente

Alerta 4

Alerta muito parecido com o **segundo alerta**, mas preciso provar isso como analista.

Nunca assumir — Sempre validar (isso é mentalidade SOC).

🧠 🔍 ANÁLISE INICIAL

👉 Mesmo padrão:

- Sender: onboarding@hrconnex.thm
- Mesmo link
- Mesmo contexto (onboarding)
- Mesma usuária: Julia Garcia

🎯 🥇 PASSO CRÍTICO

Já vi antes que:

👉 **hrconnex.thm é legítimo**

Porque:

- RH mencionou antes
- Faz parte do onboarding real

🔥 🧪 MAS COMO ANALISTA DEVO CONFIRMAR

No Splunk, fez isso antes:

index=* "hrconnex.thm"

E encontrei:

✔ Email interno validando
✔ Fluxo legítimo

🎯 💥 **CONCLUSÃO**

👉 Esse alerta é apenas outra ocorrência do mesmo evento legítimo

⚖️ **CLASSIFICAÇÃO**

👉 **False Positive**

🚨 **ESCALONAMENTO**

👉 ❌ NÃO escalar

🧠 💡 **RACIOCÍNIO PROFISSIONAL**

Não estou analisando só o alerta estou vendo o **contexto do ambiente**

M**esmo domínio + mesmo contexto + já validado**

"Recurring alert associated with previously validated legitimate activity."

📝 ✍️ RELATÓRIO FINAL

Time of activity:
05/01/2026 19:52:51

List of Affected Entities:

- User: Julia Garcia (j.garcia@thetrydaily.thm)
- Sender: onboarding@hrconnex.thm
- Host: win-3452 (10.20.2.8)

Reason for Classifying as False Positive:
This activity is classified as a False Positive. The email contains an external link and initially triggered suspicion; however, further investigation confirmed that the domain hrconnex.thm is a legitimate third-party HR service used by the organization.

Previous internal communication from the HR department confirmed that the user was expected to receive onboarding instructions from this domain. The content and timing of the email are consistent with legitimate onboarding procedures, and no malicious intent was identified.

Reason for Escalating the Alert:
Escalation is not required. The activity is verified as legitimate business communication with no signs of compromise or malicious behavior.

Recommended Remediation Actions:

- Tune detection rules to reduce similar false positives
- Consider whitelisting hrconnex.thm if appropriate
- Continue monitoring for abuse of trusted domains

List of Attack Indicators:

- Sender: onboarding@hrconnex.thm
- Recipient: j.garcia@thetrydaily.thm
- URL: https://hrconnex.thm/onboarding/15400654060/j.garcia
- Subject: Action Required: Finalize Your Onboarding Profile

Alerta 5

Lendo o alerta percebo que é um **phishing clássico de engenharia social** 👀🔥

🧠🔍 ANÁLISE RÁPIDA

👉 O que temos:

- Sender: **urgents@amazon.biz** ❌ (não é domínio oficial)
- Tema: entrega (muito comum em phishing)
- Urgência: “48 hours”
- Link encurtado: **bit.ly** ⚠️
- Usuária: Hannah Harris (RH)

🚨🔴 RED FLAGS

- Domínio falso (amazon.biz ≠ amazon.com)
- Uso de encurtador (bit.ly)
- Pressão psicológica
- Pedido de ação imediata

👉 Isso é **phishing claro**

🧠🥇 AGORA O MAIS IMPORTANTE

👉 Esse link é o MESMO do primeiro alerta:

http://bit.ly/3sHkX3da12340

✔ Foi **bloqueado pelo firewall**

🎯 💥 **CORRELAÇÃO**

Conectei:

- Email phishing
- Tentativa de acesso
- Firewall bloqueou

👉 Isso fecha o ciclo completo

⚖️ **CLASSIFICAÇÃO**

👉 **True Positive**

🚨 **ESCALONAMENTO**

👉 ❌ NÃO escalar

Por quê?

- Acesso foi bloqueado
- Sem execução
- Sem impacto

📝 ✍️ RELATÓRIO FINAL

Time of activity:
05/01/2026 19:56:04

List of Affected Entities:

- User: Hannah Harris (h.harris@thetrydaily.thm)
- Source IP: 10.20.2.17
- Host: win-3457
- Sender: urgents@amazon.biz
- Destination IP: 67.199.248.11
- URL: http://bit.ly/3sHkX3da12340

Reason for Classifying as True Positive:
This activity is classified as a True Positive due to a phishing email impersonating Amazon. The sender domain (amazon.biz) is not associated with the legitimate Amazon domain and is likely malicious. The email uses social engineering techniques such as urgency and delivery failure to trick the user into clicking a malicious link.

The embedded URL is a shortened link (bit.ly), commonly used to hide malicious destinations. Previous investigation confirmed that this URL is associated with a blacklisted destination.

Reason for Escalating the Alert:
Escalation is not required. Although the phishing attempt was confirmed, the firewall successfully blocked the outbound request to the malicious URL, preventing any connection or potential compromise. No further suspicious activity was observed.

Recommended Remediation Actions:

- Educate the user about phishing emails and suspicious links
- Block similar domains and URLs at the firewall level
- Monitor for repeated phishing attempts targeting employees
- Enhance email filtering policies

List of Attack Indicators:

- Sender: urgents@amazon.biz
- Recipient: h.harris@thetrydaily.thm
- URL: http://bit.ly/3sHkX3da12340
- Destination IP: 67.199.248.11
- Protocol: TCP
- Port: 80

Conclusão

Concluí com sucesso o ciclo completo de análise em um ambiente de Security Operations Center (SOC), aplicando uma abordagem estruturada e orientada a evidências. Durante o processo, realizei a investigação de alertas, correlacionei múltiplas fontes de dados (email e firewall), identifiquei atividades maliciosas reais, incluindo campanhas de phishing, e diferenciei com precisão entre falsos positivos e verdadeiros positivos.

Além disso, tomei decisões fundamentadas sobre a necessidade de escalonamento com base no impacto e risco identificado, e elaborei relatórios técnicos claros e detalhados, alinhados às boas práticas de resposta a incidentes.

Esse processo demonstra capacidade prática em análise de segurança, pensamento crítico e atuação alinhada aos fluxos operacionais de um SOC.

Sobre o autor

Paulo Cesar é formado em Segurança da informação pela Universidade Nove de Julho e apaixonado por Cibersegurança! Mais informações e contato:

linkedin.com/in/paulo-cesar-security